

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

STATEMENT OF APPLICABILITY ISO/IEC 27001:2022

Area 08 – Sistema Informativo

Codice	Revisione	Data	Pagine
TD-SGI-REG016_00	00	29/04/2026	17
Redatto da	Approvato da	Classificazione	Stato
RSGI + IT Manager	AD – Francesco Epifani	Riservato Alta Direzione + Auditor di certificazione	In vigore

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
29/04/2026	29/04/2026	29/04/2026

1. Scopo del documento

Il presente documento costituisce lo Statement of Applicability (SoA) richiesto dalla norma ISO/IEC 27001:2022 §6.1.3 d) per il Sistema di Gestione della Sicurezza delle Informazioni (ISMS) di Toscana Diagnostica S.r.l.

Il SoA è il documento istruttorio fondamentale dell'ISMS: dichiara per ciascuno dei 93 controlli dell'Allegato A della norma — articolati in 4 categorie A.5 (Organizational, 37 controlli), A.6 (People, 8 controlli), A.7 (Physical, 14 controlli) e A.8 (Technological, 34 controlli) — l'applicabilità al perimetro dell'ISMS di Toscana Diagnostica, la motivazione di applicabilità o esclusione, lo stato di implementazione, il riferimento ai documenti del Sistema di Gestione Integrato che ne attestano l'attuazione e il responsabile (owner) del controllo.

Il SoA è approvato dall'Alta Direzione, è soggetto a revisione almeno annuale e in occasione di qualsiasi cambiamento materiale del perimetro ISMS, dei rischi sui sistemi informativi, della normativa applicabile o della tecnologia in uso. Il SoA accompagna il Risk Assessment ISO 27005 e il Risk Treatment Plan, dei quali costituisce evidenza di applicazione operativa dei controlli.

Il documento è inteso anche come strumento istruttorio per gli audit di certificazione di terza parte: rappresenta la baseline rispetto a cui verranno verificate le evidenze di implementazione dei controlli durante le sessioni di audit. È pertanto riservato, distribuito ad Alta Direzione, IT Manager, RSGI, DPO e — su richiesta — agli Enti di certificazione e ai loro auditor.

2. Riferimenti normativi

Riferimento	Ambito
ISO/IEC 27001:2022 — Information security management systems	Norma di riferimento ISMS — perimetro del SoA (§6.1.3 d)
ISO/IEC 27002:2022 — Information security controls	Linee guida di implementazione e attributi dei 93 controlli
ISO/IEC 27005:2022 — Information security risk management	Framework di risk management su cui si fonda il SoA
ISO/IEC 27007:2020 — Guidelines for ISMS auditing	Guida agli audit di terza parte
ISO/IEC 27017:2015 — Cloud services security	Estensione dei controlli ai servizi cloud (A.5.23)
ISO/IEC 27018:2019 — Cloud privacy	Allineamento ai PII processor cloud
ISO/IEC 27701:2019 — Privacy Information Management	PIMS in roadmap post 27001
NIST Cybersecurity Framework 2.0	Mappatura attributi controlli (Identify-Protect-Detect-Respond-Recover-Govern)
D.Lgs. 138/2024 (NIS2)	Coerenza con MTOM dell'art. 24 — vedi PLN009
AI Act Reg. UE 2024/1689	Coerenza con governance AI — vedi PRO085
GDPR Reg. UE 2016/679	Coerenza con privacy — Area 09 + DPO

3. Ambito dell'ISMS

L'ISMS di Toscana Diagnostica S.r.l. ha il perimetro funzionale, geografico, organizzativo, normativo e tecnologico di seguito definito.

3.1 Perimetro funzionale e di servizi

L'ISMS copre tutti i processi, sistemi e informazioni connessi alla erogazione dei servizi di laboratorio analisi e diagnostica per immagini di Toscana Diagnostica S.r.l., includendo: accettazione paziente, esecuzione esami diagnostici (chimica clinica, immunologia, microbiologia, anatomia patologica, ematologia, genetica, radiologia, risonanza magnetica, ecografia, TC), refertazione, consegna dei referti al paziente e al SSN, fatturazione, archiviazione documentale, processi di supporto (HR, finance, procurement, IT, qualità).

3.2 Perimetro geografico

Sede legale e operativa di Viale Belfiore 55, 50144 Firenze. Eventuali sedi/punti prelievo periferici di Toscana Diagnostica sono ricompresi nello stesso perimetro ISMS.

3.3 Perimetro organizzativo

Tutto il personale di Toscana Diagnostica (dipendenti, collaboratori, consulenti, fornitori in servizio presso TD) ha doveri di conformità all'ISMS. Ruoli specifici dell'ISMS:

Ruolo	Responsabilità sull'ISMS
Alta Direzione (AD/Legale Rappresentante)	Approvazione del SoA, allocazione risorse, accountability ultima ex §5
RSGL	Gestione operativa dell'ISMS, audit interno, manutenzione SoA, coordinamento controlli
IT Manager	Implementazione tecnica dei controlli A.7 (Physical) e A.8 (Technological)
DPO	Coordinamento controlli che impattano dati personali (A.5.34, A.7.10, A.8.10, A.8.11)
RSPP	Coordinamento controlli fisici e ambientali (A.7.1-A.7.6)
P&C Manager	Implementazione controlli A.6 (People)
PdC NIS	Gestione controlli incident response (A.5.24-A.5.28) integrati con NIS2
MSSP / SOC esternalizzato	Esecuzione controlli detection (A.8.7, A.8.15-A.8.16, A.8.20)
OdV 231	Coordinamento per controlli rilevanti per cyber-reati 231
Internal Auditor	Esecuzione audit interno (A.5.35, A.8.34)

3.4 Perimetro normativo

L'ISMS opera in coerenza e sinergia con le seguenti norme/regolamenti che TD applica: ISO 9001 (qualità), ISO 7101 (eccellenza sanitaria), ISO 45001 (SSL), ISO 14001 (ambiente), ISO 30415 (D&I), UNI PdR 125 (parità di genere), PAS 24000 (sostenibilità), ISO 37001 (anti-corruzione), Modello 231 (responsabilità amministrativa), GDPR (privacy), NIS2 (cybersecurity), AI Act (governance AI), ISO 15189 (laboratori medici).

3.5 Perimetro tecnologico

Sistemi nel perimetro ISMS: LIS (Laboratory Information System), RIS (Radiology Information System), PACS (Picture Archiving and Communication System), middleware analitico per strumentazione IVD, portale refertazione paziente, sistemi amministrativi (ERP, HRM, contabilità, fatturazione elettronica), conservazione sostitutiva digitale, posta elettronica e collaboration M365, infrastruttura di rete (firewall, switch, AP, VPN), endpoint (workstation, notebook, tablet medici, smartphone aziendali), datacenter primario in colocation, backup off-site cifrato.

4. Criteri di applicabilità e di esclusione

Per ogni controllo dell'Allegato A, l'applicabilità è valutata sulla base dei seguenti criteri:

- (a) presenza di un rischio identificato nell'analisi del rischio ISO 27005 a cui il controllo offre mitigazione;
- (b) requisito legale, regolamentare o contrattuale che impone il controllo (ad es. NIS2 art. 24 c. 2 prevede esplicitamente diverse aree MTOM mappabili a A.5/A.6/A.8);
- (c) requisito di buona prassi del settore sanitario (es. controlli su Category 9 GDPR, su strumentazione IVD, su protezione dei referti);
- (d) requisito di compliance con altre certificazioni in roadmap (ISO 27701, ISO 22301, ISO 42001).

Un controllo è dichiarato "Non Applicabile" solo quando è oggettivamente non rilevante per il perimetro ISMS dichiarato — ad esempio, controlli sullo sviluppo software interno saranno mantenuti applicabili anche per la limitata superficie di sviluppo (script di automazione + integrazioni AI), perché la non applicabilità totale richiederebbe di escludere a priori qualsiasi sviluppo di codice. Nella presente prima emissione, in coerenza con un approccio cautelativo pre-certificazione, tutti i 93 controlli sono dichiarati Applicabili.

5. Stati di implementazione e legenda

Codice	Stato	Definizione
I	Implementato	Controllo pienamente operativo, con evidenza documentale e operativa
P	Parzialmente implementato	Controllo operativo ma con gap di copertura, formalizzazione o cadenza
PL	Pianificato	Controllo non ancora operativo, con piano formale di implementazione e scadenza
NI	Non implementato	Controllo applicabile ma senza piano formale (richiede CAPA)

Per ciascun controllo sono inoltre dichiarati gli attributi previsti da ISO 27002:2022 (Type, Information Security Properties, Cybersecurity Concept, Operational Capability, Security Domain) — facoltativi nello standard ma indicativi dell'allineamento con frameworks di riferimento (in particolare NIST CSF 2.0).

6. Sintesi dello stato di implementazione

Su 93 controlli totali dell'Allegato A:

- 93 sono Applicabili (100%);
- 0 sono Non Applicabili (0%);
- 12 sono pienamente Implementati (13% degli applicabili);
- 64 sono Parzialmente implementati (69% degli applicabili);
- 17 sono Pianificati (18% degli applicabili);
- 0 sono Non implementati senza piano formale (0% degli applicabili).

Sintesi per categoria:

Categoria	Totale	Implementati	Parziali	Pianificati	Non impl.	Maturità
A.5 Organizational	37	7	20	10	0	46%

Controls						
A.6 People Controls	8	0	8	0	0	50%
A.7 Physical Controls	14	0	13	1	0	46%
A.8 Technological Controls	34	5	23	6	0	49%
TOTALE	93	12	64	17	0	47%

Il calcolo della maturità adotta una metrica conservativa: gli Implementati pesano 1.0, i Parzialmente implementati 0.5, i Pianificati e i Non implementati 0. La maturità complessiva attuale è dell'ordine del 50% — coerente con un ISMS in fase di consolidamento documentale, in attesa di chiusura della NC Maggiore P1 sul presente SoA (RPT003 finding #21) e dei piani di adeguamento previsti.

7. Tabella dei 93 controlli dell'Allegato A

La presente tabella elenca per ciascuno dei 93 controlli dell'Allegato A di ISO/IEC 27001:2022 le seguenti informazioni:

- ID e titolo del controllo;
- Type: tipologia secondo ISO 27002:2022 §4.2 (P=Preventive, D=Detective, C=Corrective);
- IS Property: proprietà di sicurezza interessata (C=Confidentiality, I=Integrity, A=Availability);
- Cybersecurity Concept: NIST CSF 2.0 (ID=Identify, PR=Protect, DT=Detect, RS=Respond, RC=Recover);
- Operational Capability: capacità operativa secondo 27002 §4.5;
- Security Domain: dominio di sicurezza secondo 27002 §4.6 (Governance and Ecosystem, Protection, Defence, Resilience);
- Applicabilità (A=Applicabile, NA=Non Applicabile);
- Motivazione di applicabilità (o di esclusione);
- Riferimento al SGI di TD (documenti, piani, procedure);
- Stato di implementazione (I=Implementato, P=Parziale, PL=Pianificato, NI=Non implementato);
- Owner del controllo.

7.1 A.5 — Organizational Controls (37 controlli)

ID	Titolo	Type	IS Pr	CSC	Sec Domain	Ap p	Motivazione	Riferimento SGI	Stat o	Owner
A.5.1	Politiche per la sicurezza delle informazioni	P	C+I+A	ID	Governance and Ecosystem	A	Requisito fondamentale e ISMS - politica obbligatoria.	POL001 (in revisione per dedicare sezione IS); POL002 IS Policy raccomandata da RPT003 (P1, 30/06/2026)	PL	AD + RSGI
A.5.2	Ruoli e responsabilità per la sicurezza delle informazioni	P	C+I+A	ID	Governance and Ecosystem	A	Necessari per assegnare accountability e ISMS.	MOD200 PdC NIS; PRO070 §4 (matrice responsabilità); MAN001 §5	P	AD + RSGI
A.5.3	Segregazione dei compiti	P	C+I	PR	Governance and Ecosystem	A	Critico per laboratorio: separazione fra accettazione, esecuzione,	Da formalizzare in REG021 Mansionario aziendale (P1 RPT003)	P	P&C Manager + RSGI

							refertazione.		
A.5.4	Responsabilità della Direzione	P	C+I+A	ID	Governance and Ecosystem	A	Obbligatorio - clausola §5 ISO 27001.	PRO008 Riesame della Direzione; verbali Riesame (da formalizzare 2026)	P AD
A.5.5	Contatti con le autorità	P	C+I+A	ID+RS	Defence	A	ACN (NIS2), Garante (GDPR), CSIRT, Polizia Postale, AIFA, Min. Salute - rete attiva.	PRO070 §6 (catena risposta); MOD200 designazione PdC NIS; MOD184 checklist notifiche	I AD (PdC NIS) + DPO
A.5.6	Contatti con gruppi di interesse speciale	P	C+I+A	ID+DT	Defence	A	ENISA, ISACs sanitari, gruppi locali cybersecurity, vendor advisory.	Da formalizzare quale lista contatti in PLN009 §4 (governance ISMS)	PL IT Manager + RSGI
A.5.7	Threat intelligence	P+D	C+I+A	ID+DT	Defence	A	Settore sanitario è target #1 (ENISA). MSSP/SOC fornisce TI.	Contratto SOC esternalizzato; MOD182 - fornitore SOC come critico; PLN009 area MTOM 1	P IT Manager + MSSP
A.5.8	Sicurezza delle informazioni nella gestione dei progetti	P	C+I+A	PR	Protection	A	Tutti i progetti TD (digitalizzazione, integrazione LIS, AI) devono includere security by design.	Da integrare in PRO086 Change Management ICT (P1 RPT003, 31/07/2026)	PL IT Manager + RSGI
A.5.9	Inventario di informazioni e altri asset associati	P	C+I+A	ID	Governance and Ecosystem	A	Asset register obbligatorio - oggi al 80% copertura endpoint.	MOD050 Inventario asset; CMDB in roadmap PLN009 area MTOM 9 al 100% entro 31/08/2026	P IT Manager
A.5.10	Uso accettabile delle informazioni e altri asset associati	P	C+I+A	PR	Protection	A	Acceptable Use Policy per tutto il personale.	Da emettere come parte di POL002 IS Policy (P1 RPT003)	PL RSGI + P&C
A.5.11	Restituzione degli asset	P	C+I+A	PR	Protection	A	JML - restituzione asset alla cessazione del rapporto.	PRO040 (?) JML; MOD HR per restituzione (verifica esistenza)	P P&C + IT Manager
A.5.12	Classificazione delle	P	C+I	PR	Protection	A	Classificazioni	Da emettere come POL	PL DPO + RSGI

	informazioni						obbligatoria - dati clinici sono Category 9 GDPR.	specificata - sub-policy di POL002 IS Policy (P1 RPT003)		
A.5.13	Etichettatura delle informazioni	P	C+I	PR	Protection	A	Etichettatura coerente con classificazione di A.5.12.	Da formalizzare con A.5.12	PL	RSGI + IT Manager
A.5.14	Trasferimento delle informazioni	P	C+I	PR	Protection	A	Refertazione paziente, scambio con SSN, fornitori - tutti via canali cifrati.	PRO030-037 procedure Privacy; PRO034 gestione credenziali	P	DPO + IT Manager
A.5.15	Controllo degli accessi	P	C+I+ A	PR	Protection	A	Active Directory + IAM applicativo, RBAC in implementazione.	PRO034; PLN009 area MTOM 9 (RBAC + PAM al 1/10/2026)	P	IT Manager
A.5.16	Gestione delle identità	P	C+I	PR	Protection	A	Identity lifecycle: J/M/L documentato con ticket IT.	PRO034; PLN009 area MTOM 9 (JML automation entro 31/08/2026)	P	IT Manager + P&C
A.5.17	Informazioni di autenticazione	P	C	PR	Protection	A	Password policy attiva - aggiornamento NIST SP 800-63B in roadmap.	PRO034; PLN009 area MTOM 7 (policy aggiornata entro 30/06/2026)	P	IT Manager
A.5.18	Diritti di accesso	P	C+I	PR	Protection	A	Riesame periodico diritti - cadenza semestrale prevista.	PRO034; cruscotto IAM mensile da consolidare	P	IT Manager
A.5.19	Sicurezza delle informazioni nei rapporti con i fornitori	P	C+I+ A	PR	Governance and Ecosystem	A	Critico per NIS2 - 12 fornitori critici identificati.	PRO017 Qualifica fornitori; MOD182 Inventario Fornitori ICT; PRO070 §8 (8 clausole NIS2)	P	IT Manager + Procurement
A.5.20	Indirizzo della sicurezza delle informazioni negli accordi con i fornitori	P	C+I+ A	PR	Governance and Ecosystem	A	8 clausole NIS2 obbligatorie sui contratti dei fornitori critici.	PRO070 §8 + addendum contrattuali in roadmap (90% al 1/10/2026)	P	Legal + Procurement
A.5.21	Gestione della sicurezza delle informazioni nella catena di approvvigionamento ICT	P	C+I+ A	PR	Governance and Ecosystem	A	Sub-fornitori dichiarati nel MOD182 - rischio di 4-th party.	MOD182 colonna sub-fornitori; due diligence allineata a 27036	P	IT Manager + Procurement
A.5.	Monitoraggio,	D+	C+I+	DT+	Defence	A	Audit fornitori	PRO095 Audit	PL	RSGI +

22	riesame e gestione del cambiamento dei servizi del fornitore	P	A	RS			critici programmati - rotazione triennale 30%/anno.	Fornitori Critici (P2 RPT003)		Procurement
A.5. 23	Sicurezza delle informazioni per l'uso di servizi cloud	P	C+I+ A	PR	Protection	A	M365, AWS/Azure cloud, SaaS sanitari (LIS, RIS, PACS) tutti su modelli condivisi.	Cloud governance da formalizzare in PRO086 Change Management ICT	P	IT Manager
A.5. 24	Pianificazione e preparazione della gestione degli incidenti di sicurezza delle informazioni	P	C+I+ A	RS	Defence	A	Catena di risposta NIS2 a 5 fasi documentata	PRO070 §6; MOD181 Registro Incidenti; MOD183 Tabletop; MOD184 Checklist; IDL026 Trasmissione ACN	I	PdC NIS + RSGI
A.5. 25	Valutazione e decisione sugli eventi di sicurezza delle informazioni	P+ D	C+I+ A	DT+ RS	Defence	A	Triage SOC + classificazione e significatività NIS2.	PRO070 §6; tassonomia §3 MOD181; SOC esternalizzato	I	PdC NIS + IT Manager + MSSP
A.5. 26	Risposta agli incidenti di sicurezza delle informazioni	C	C+I+ A	RS+ RC	Defence	A	Catena 5 fasi T0+24h/72h/30gg verso CSIRT Italia.	PRO070 §6; IDL026; MOD184	I	PdC NIS + IT Manager
A.5. 27	Apprendimento dagli incidenti di sicurezza delle informazioni	P	C+I+ A	ID+R S	Defence	A	RCA + CAPA + lessons learned obbligatori per ogni incidente significativo.	MOD181 §4 voci 19-21; PRO070 §6 fase 5	I	RSGI + IT Manager
A.5. 28	Raccolta delle prove	P	C+I	RS	Defence	A	Forensic readiness - archiviazione log e artefatti digitali.	IDL026 §8 Tracciabilità documentale; archivio /SGI/NIS2/incidenti/	P	IT Manager + Legal
A.5. 29	Sicurezza delle informazioni durante interruzioni	P	C+I+ A	PR+ RC	Resilience	A	Continuità ICT durante eventi disruptive - oggi 30%, gap principale del SGI.	PLN013 BCP (P1 RPT003, 31/07/2026); PLN014 DRP (P1 RPT003, 31/07/2026)	PL	IT Manager + AD
A.5. 30	Preparazione ICT per la continuità operativa	P	C+I+ A	PR+ RC	Resilience	A	ICT readiness coerente con BCMS aziendale.	PLN013 BCP + PLN014 DRP; PLN009 area MTOM 3	PL	IT Manager
A.5. 31	Requisiti legali, statutarî,	P	C+I+ A	ID	Governance and	A	10+ norme tracciate;	RPT003 Report Audit;	P	RSGI + Legal

	regolamentari e contrattuali				Ecosyste m		registro obblighi ambientali in roadmap (MOD208).	RPT002 Benchmark Q2 2026; MOD208 (P1 RPT003)		
A.5.32	Diritti di proprietà intellettuale	P	C+I	PR	Protectio n	A	Software licenses, IP aziendale, dati di laboratorio per ricerca.	PRO017 procurement; gestione licenze SW da consolidare in inventario CMDDB	P	Legal + IT Manager
A.5.33	Protezione dei record	P	C+I+ A	PR	Protectio n	A	Conservazio ne referti medici 10+ anni; record contabili 10 anni.	PRO058 Data Retention; conservatore digitale a norma (fornitore critico)	I	DPO + IT Manager
A.5.34	Privacy e protezione dei PII	P	C+I	PR	Protectio n	A	Categoria 9 GDPR - dati clinici. Privacy by design e by default ex art. 25.	PRO030-037 (8 procedure Privacy); MOD028-029 + REG004	I	DPO
A.5.35	Riesame indipendente della sicurezza delle informazioni	D	C+I+ A	ID	Governa nce and Ecosyste m	A	Audit interno annuale + audit terzo certificativo.	PRO007 Audit interno; PLN006 Piano audit; MOD214 Verbale Audit (P1 RPT003)	PL	RSGI / Internal Auditor
A.5.36	Conformità con politiche, regole e standard per la sicurezza delle informazioni	P+ D	C+I+ A	ID	Governa nce and Ecosyste m	A	Verifica conformità periodica - cruscotto KPI ISMS.	PRO007; cruscotto NIS2 mensile RSGI	P	RSGI
A.5.37	Procedure operative documentate	P	C+I+ A	PR	Protectio n	A	Procedure operative ICT (backup, restore, monitoraggio, hardening, etc.).	Set procedure Area 08 (PRO016-019); IDL operative del laboratorio (Area 18)	P	IT Manager + RSGI

7.2 A.6 — People Controls (8 controlli)

ID	Titolo	Typ e	IS Pr	CSC	Sec Domain	Ap p	Motivazione	Riferimento SGI	Stat o	Owner
A.6.1	Selezione del personale	P	C+I	PR	Governan ce and Ecosyste m	A	Background check coerente con normativa lavoro - personale strategico verificato.	PRO038-PRO044 procedure HR; background check da formalizzare per ruoli critici	P	P&C Manager
A.6.2	Termini e condizioni di	P	C+I	PR	Governan ce and	A	Clausole IS nei contratti	PRO040 (?) onboarding;	P	P&C + Legal

	impiego				Ecosyste m		di lavoro.	clausole standard CCNL Sanità Privata + clausole IS aggiuntive		
A.6. 3	Sensibilizzazio ne, formazione e addestramento sulla sicurezza delle informazioni	P	C+I+ A	PR	Protection	A	8h/anno per tutto il personale + 16h/anno per ICT/Alta Direzione + AI literacy art. 4 AI Act.	PLN007 Piano formativo; MOD007 (?) Registro formazione; PLN009 area MTOM 7 (in erogazione 2026)	P	RSGI + P&C + IT Manager
A.6. 4	Processo disciplinare	C	C+I+ A	RS	Governan ce and Ecosyste m	A	Sanzioni disciplinari per violazioni IS - allineate al CCNL.	Codice Etico (REG018 in adozione); CCNL Sanità Privata art. disciplinari	P	P&C + Funzione di Conformi tà
A.6. 5	Responsabilità dopo la cessazione o cambio di impiego	P	C+I	PR	Governan ce and Ecosyste m	A	Obblighi di riservatezza post- employment - clausole NDA standard.	Clausole NDA in PRO040 onboarding; clausole post- employment di legge	P	P&C + Legal
A.6. 6	Accordi di confidenzialità o di non divulgazione	P	C	PR	Governan ce and Ecosyste m	A	NDA con dipendenti, fornitori, consulenti.	Modulistica HR standard; PRO017 procurement con clausole NDA	P	Legal + P&C
A.6. 7	Lavoro da remoto	P	C+I+ A	PR	Protection	A	Smart working presente - VPN attiva, MFA obbligatorio.	PRO034 gestione credenziali; ZTNA in roadmap PLN009 area MTOM 8 (1/10/2026)	P	IT Manager + P&C
A.6. 8	Reporting di eventi di sicurezza delle informazioni	P+ D	C+I+ A	DT+R S	Defence	A	Whistleblowi ng channel + canale interno IS event reporting.	PRO003 Whistleblowi ng (D.Lgs. 24/2023); MOD181 Registro Incidenti; PRO070 §5 (segnalazion i)	P	PdC NIS + Funzione di Conformi tà

7.3 A.7 — Physical Controls (14 controlli)

ID	Titolo	Typ e	IS Pr	CS C	Sec Domain	Ap p	Motivazione	Riferimento SGI	Stat o	Owner
A.7.1	Perimetri di sicurezza fisica	P	C+I+ A	PR	Protectio n	A	Sede TD presidio fisico - perimetro definito; datacenter in colocation con perimetro fornitore.	Documentazio ne fisica RSPP; controlli accesso datacenter (fornitore certificato)	P	RSPP + IT Manag er
A.7.2	Ingresso fisico	P	C+I+ A	PR	Protectio n	A	Accesso ai locali con badge - aree riservate (LIS, archivio referti, server room).	Procedura accesso fisico (RSPP); badge attivi; videosorveglia nza	P	RSPP
A.7.3	Sicurezza degli uffici, locali e strutture	P	C+I+ A	PR	Protectio n	A	Locali con accesso controllato - zone laboratorio con accesso limitato.	Documentazio ne RSPP; planimetrie con classificazione zone	P	RSPP
A.7.4	Monitoraggio della sicurezza fisica	D	C+I+ A	DT	Defence	A	Videosorveglia nza attiva - sistema di allarme antintrusione.	Sistema TVCC; allarme; conservazione registrazioni 30gg (compliance Garante)	P	RSPP + DPO
A.7.5	Protezione dalle minacce fisiche e ambientali	P	C+I+ A	PR	Protectio n	A	Antincendio, controllo umidità, controllo accessi, allagamenti.	Documentazio ne RSPP; manutenzione antincendio annuale; PLN012 Piano Emergenza (P1 RPT003)	P	RSPP
A.7.6	Lavorare in aree sicure	P	C+I	PR	Protectio n	A	Aree laboratorio: accesso solo personale autorizzato + DPI.	Procedure RSPP; IDL003 igiene mani; MOD007 DPI	P	RSPP + Direttore Lab
A.7.7	Scrivania pulita e schermo pulito	P	C	PR	Protectio n	A	Clean desk policy - oggi prassi consolidata, non formalizzata come policy.	Da emettere come parte di POL002 IS Policy	PL	RSGI
A.7.8	Posizioname nto e protezione dei dispositivi	P	C+I+ A	PR	Protectio n	A	Strumentazione di laboratorio in aree dedicate; endpoint in postazioni controllate.	Inventario asset MOD050; documentazione e RSPP	P	IT Manag er + RSPP
A.7.9	Sicurezza degli asset al di fuori dei	P	C+I+ A	PR	Protectio n	A	Notebook smart working, tablet medico,	PRO034 gestione credenziali;	P	IT Manag er

	locali						dispositivi mobili.	cifratura endpoint in roadmap PLN009 area MTOM 8		
A.7.10	Storage media	P	C+I	PR	Protection	A	Backup off-site cifrato; gestione dispositivi removibili.	Provider cloud backup (fornitore critico MOD182); procedura USB/removibili in PRO086 (P1)	P	IT Manager
A.7.11	Servizi di supporto	P	A	PR	Resilience	A	UPS, generatore, climatizzazione, alimentazione - asset critici.	Manutenzione fornitore; cruscotto monitoraggio data center	P	IT Manager + RSPP
A.7.12	Sicurezza dei cablaggi	P	C+I+A	PR	Protection	A	Cablaggi protetti in canaline; rete segregata in VLAN.	Documentazione di rete IT; topologia VLAN documentata	P	IT Manager
A.7.13	Manutenzione delle apparecchiature	P	I+A	PR	Protection	A	Manutenzione strumenti laboratorio (ISO 15189 §6.5) e ICT.	Programmi manutenzione lab + ICT; registri manutenzione (Area 18)	P	IT Manager + Direttore Lab
A.7.14	Smaltimento sicuro o riutilizzo delle apparecchiature	P	C	PR	Protection	A	Sanitizzazione disk drive; smaltimento HW conforme RAEE.	Procedura interna IT (manuale); fornitore RAEE qualificato	P	IT Manager

7.4 A.8 — Technological Controls (34 controlli)

ID	Titolo	Tip e	IS Pr	CSC	Sec Domain	App	Motivazione	Riferimento SGI	Stato	Owner
A.8.1	Dispositivi degli utenti finali	P	C+I+A	PR	Protection	A	EDR su tutti gli endpoint; hardening baseline in roadmap.	PLN009 area MTOM 7 (CIS Benchmark Tier 1 al 30/09/2026)	P	IT Manager
A.8.2	Diritti di accesso privilegiati	P	C+I+A	PR	Protection	A	PAM in roadmap - oggi controllo manuale account admin.	PLN009 area MTOM 9 (PAM operativo entro 1/10/2026)	PL	IT Manager
A.8.3	Restrizione dell'accesso alle informazioni	P	C+I	PR	Protection	A	Need-to-know enforced via RBAC applicativo (LIS, RIS, PACS).	Configurazione e applicativi; PRO034	P	IT Manager + Direttore Lab
A.8.4	Accesso al codice sorgente	P	C+I	PR	Protection	A	Sviluppo interno limitato - codice script automazione su Git interno.	Repository interno con accesso limitato; procedura formale in	P	IT Manager

								PRO086 (P1)		
A.8.5	Autenticazione sicura	P	C	PR	Protection	A	MFA su mail, VPN, console amministrativa - universale entro 30/09/2026.	PRO034; PLN009 area MTOM 10 (MFA universale)	P	IT Manager
A.8.6	Gestione della capacità	P+D	A	PR+DT	Resilience	A	Capacity planning su risorse critiche (storage referti, banda di rete).	Monitoraggio capacità via SOC + cruscotti vendor	P	IT Manager
A.8.7	Protezione contro il malware	P+D	C+IA	PR+DT	Defence	A	EDR + antimalware su tutti gli endpoint e server.	EDR fornitore (MOD182); aggiornamenti o signature 24h	I	IT Manager + MSSP
A.8.8	Gestione delle vulnerabilità tecniche	P+D	C+IA	ID+PR	Protection	A	Patch management mensile (sistemi critici); VAPT da formalizzare.	PRO094 Vulnerability Management (P1 RPT003); PLN009 area MTOM 5	PL	IT Manager
A.8.9	Gestione della configurazioni	P	C+IA	PR	Protection	A	Configurazioni baseline da formalizzare; CMDB in costruzione.	PRO086 Change Management (P1 RPT003); CMDB completa entro 31/08/2026	PL	IT Manager
A.8.10	Cancellazione delle informazioni	P	C	PR	Protection	A	Data retention coerente con normativa sanitaria + GDPR.	PRO058 Data Retention; sanitizzazione e media (A.7.14)	I	DPO + IT Manager
A.8.11	Mascheramento dei dati	P	C	PR	Protection	A	Pseudonimizzazione per ricerca clinica e training AI - art. 89 GDPR.	PRO085 §6 (anonimizzazione AI); procedura ricerca clinica da formalizzare	P	DPO + Direttore Sanitario
A.8.12	Prevenzione della perdita di dati	P+D	C	PR+DT	Protection	A	DLP non implementato - gap; oggi controlli manuali su email outbound.	Da pianificare in PLN009 area MTOM 8; DLP solution Q4 2026	PL	IT Manager
A.8.13	Backup delle informazioni	P	I+A	PR+RC	Resilience	A	Backup giornaliero LIS/RIS/PACS con retention 90gg; off-site cifrato.	Provider cloud backup MOD182; test di ripristino 1/anno (gap: portare a 2/anno)	P	IT Manager
A.8.14	Ridondanza delle strutture per il trattamento delle informazioni	P	A	PR+RC	Resilience	A	Server LIS in cluster; storage ridondato; rete con doppia uplink.	Documentazione architettura in PLN014 DRP (P1)	P	IT Manager

A.8.15	Logging	D	C+I+ A	DT	Defence	A	Centralized logging via SIEM esternalizzato (MSSP).	SOC con SIEM; retention log 12 mesi (NIS2 art. 24)	P	IT Manager + MSSP
A.8.16	Attività di monitoraggio	D	C+I+ A	DT+RS	Defence	A	SOC 24x7 monitora servizi critici; allarmi configurati su threat.	Contratto SOC con KPI di reattività	I	MSSP + IT Manager
A.8.17	Sincronizzazione dell'orologio	P	I	PR	Protection	A	NTP centralizzato; coerenza per audit log legali.	Configurazione NTP su domain controller + LIS	I	IT Manager
A.8.18	Uso di programmi di utilità privilegiati	P	C+I+ A	PR	Protection	A	Limitazione tool admin; tracciatura uso PowerShell, etc.	Da formalizzare in PRO094 Vulnerability Management	P	IT Manager
A.8.19	Installazione di software sui sistemi operativi	P	C+I+ A	PR	Protection	A	Solo software approvato; whitelist applicazioni in roadmap.	Policy da emettere in POL002 IS Policy + endpoint management	P	IT Manager
A.8.20	Sicurezza delle reti	P	C+I+ A	PR	Protection	A	Segregazione VLAN; firewall perimetrali; IDS/IPS attivi.	Documentazione di rete; SOC monitora	P	IT Manager + MSSP
A.8.21	Sicurezza dei servizi di rete	P	C+I+ A	PR	Protection	A	Servizi di rete (DNS, DHCP, web, mail) hardenati e monitorati.	SLA fornitori connettività; SOC; ZTNA in roadmap (1/10/2026)	P	IT Manager
A.8.22	Segregazione delle reti	P	C+I	PR	Protection	A	Segregazione VLAN: clinica, amministrativa, ospiti, IoT medico.	Topologia VLAN; isolamento IoT medico (modalità di accesso vincolata)	P	IT Manager
A.8.23	Filtraggio web	P	C+I	PR	Protection	A	Web filtering attivo via firewall + endpoint.	Configurazione firewall e endpoint security	I	IT Manager + MSSP
A.8.24	Uso di crittografia	P	C+I	PR	Protection	A	Cifratura at-rest DB clinici; in-transit TLS 1.2/1.3; key management da centralizzare.	PLN009 area MTOM 8 (POL003 Crittografia + KMS al 1/10/2026)	P	IT Manager
A.8.25	Ciclo di vita di sviluppo sicuro	P	C+I+ A	PR	Protection	A	Sviluppo interno limitato; SDLC sicuro per script + integrazioni AI.	Da formalizzare per integrazioni AI in coordinamento con PRO085 §5	P	IT Manager
A.8.26	Requisiti di sicurezza	P	C+I+ A	PR	Protection	A	Requisiti IS in fase di	PRO017 + checklist	P	IT Manager

	dell'applicazione						selezione SaaS sanitari (PRO017).	requisiti IS in procurement ICT		+ Procurement
A.8.27	Architettura di sistema sicura e principi di engineering	P	C+I+A	PR	Protection	A	Defense in depth; zero-trust; least privilege - principi guida.	Documentazione architetturale; PLN013/014 BCP/DRP	P	IT Manager + RSGI
A.8.28	Codifica sicura	P	C+I+A	PR	Protection	A	Code review interno per script automazione; SAST/DAST in roadmap.	Procedura sviluppo interno (manuale); SAST tool da valutare	P	IT Manager
A.8.29	Test di sicurezza nello sviluppo e nell'accettazione	P+D	C+I+A	PR+DT	Protection	A	VAPT annuale obbligatorio; PT pre-deployment per sistemi critici.	PRO094 Vulnerability Management (P1); PLN009 area MTOM 5	PL	IT Manager + RSGI
A.8.30	Sviluppo affidato a terzi	P+D	C+I+A	ID+PR	Protection	A	Vendor management su LIS/RIS/PACS - sviluppo affidato a fornitori.	MOD182 Inventario Fornitori; clausole NIS2 in PRO070 §8	P	IT Manager + Procurement
A.8.31	Separazione di ambienti di sviluppo, test e produzione	P	C+I+A	PR	Protection	A	Per LIS: ambiente test/UAT separato da produzione (richiesto vendor).	Configurazione e vendor LIS/RIS; documentazione architetturale	P	IT Manager
A.8.32	Gestione del cambiamento	P	C+I+A	PR	Protection	A	Change management ICT - oggi gestione informale, da formalizzare.	PRO086 Change Management ICT (P1 RPT003, 31/07/2026)	PL	IT Manager
A.8.33	Informazioni di test	P	C	PR	Protection	A	Test data: anonimizzazione e obbligatoria su dati clinici reali.	Procedura ad hoc su anonimizzazione; coordinamento con DPIA AI (PRO085)	P	DPO + IT Manager
A.8.34	Protezione dei sistemi informativi durante l'audit	P	I+A	PR	Protection	A	Procedure audit non disruptive; coordinamento RSGI-IT Manager.	PRO007 Audit interno; coordinamento operativo con audit di terza parte	P	RSGI + IT Manager

8. Controlli aggiuntivi non Annex A

ISO/IEC 27001:2022 §6.1.3 c) consente di includere controlli aggiuntivi rispetto all'Allegato A quando necessari per il trattamento del rischio. Toscana Diagnostica include in modo formale i seguenti controlli aggiuntivi derivanti dalle norme/regolamenti settoriali applicabili:

ID interno	Titolo del controllo	Fonte	Riferimento SGI	Stato	Owner
------------	----------------------	-------	-----------------	-------	-------

TD.NIS2.01	Designazione formale del Punto di Contatto NIS	D.Lgs. 138/2024 art. 7	MOD200	I	AD + RSGI
TD.NIS2.02	Notifica incidenti significativi al CSIRT entro T0+24h/72h/30gg	D.Lgs. 138/2024 art. 25	PRO070 §6 + MOD181 + MOD184 + IDL026	I	PdC NIS
TD.NIS2.03	Aggiornamento periodico del Portale ACN	D.Lgs. 138/2024 art. 7	PRO070 §5	I	PdC NIS
TD.AI.01	Classificazione dei sistemi AI secondo le 4 fasce AI Act	Reg. UE 2024/1689 art. 6-7	PRO085 §4 + MOD197	I	AD + DPO + RSGI
TD.AI.02	Procedura HITL su LIS per output AI	Reg. UE 2024/1689 art. 14	IDL034	I	Direttore Sanitario
TD.AI.03	Notifica incidenti gravi AI ad AI Office UE / AgID-ACN	Reg. UE 2024/1689 art. 73	MOD199	I	PdC NIS + DPO
TD.IVDR.01	Vigilanza post-market dispositivi IVD	Reg. UE 2017/746 art. 82	PRO105 (P1 RPT003 - in emissione)	PL	Direttore Sanitario
TD.GDPR.01	Tassonomia data breach + cadenza 72h al Garante	GDPR artt. 33-34	PRO030-037 + MOD184 §4	I	DPO

Tali controlli aggiuntivi non sostituiscono i controlli dell'Allegato A ma si affiancano ad essi per coprire requisiti settoriali e regolamentari specifici di TD. Sono parte integrante del SoA e oggetto di audit interno.

9. Approvazione del SoA

Il presente Statement of Applicability è approvato dall'Alta Direzione di Toscana Diagnostica S.r.l. nella persona del Legale Rappresentante e Amministratore Delegato, ai sensi di ISO/IEC 27001:2022 §5.1 (leadership e impegno) e §6.1.3 d).

L'approvazione comporta l'impegno formale dell'Alta Direzione a:

- (a) allocare le risorse economiche, tecnologiche e organizzative necessarie all'attuazione dei controlli applicabili;
- (b) garantire la realizzazione del piano di chiusura dei controlli oggi Pianificati o Parzialmente implementati, in coerenza con le scadenze del Piano di Adeguamento MTOM (PLN009) e del Report di Audit Documentale (RPT003);
- (c) sottoporre il SoA a revisione almeno annuale e in occasione di ogni cambiamento materiale nel perimetro ISMS.

L'Alta Direzione (approvante)

AD – Francesco Epifani

Firma: _____

Data: ____/____/____

RSGI (redattore)

Iacopo Cupelli

Firma: _____

Data: ____/____/____

10. Riesame e manutenzione del SoA

Il SoA è soggetto a:

- (a) riesame periodico almeno annuale a cura del RSGI con il supporto dell'IT Manager — di norma entro 60 giorni dall'audit interno annuale dell'ISMS;

(b) riesame straordinario in occasione di: nuove minacce significative emerse da threat intelligence; cambiamenti materiali del perimetro ISMS; modifiche alla normativa di riferimento; aggiornamenti maggiori della ISO/IEC 27001 o della 27002; risultanze rilevanti da audit interni o di terza parte;

(c) verifica documentale almeno semestrale del cruscotto stato di implementazione.

Le modifiche al SoA sono tracciate nello storico delle revisioni e — quando comportino una variazione materiale (passaggio di un controllo da Applicabile a Non Applicabile, modifica del perimetro ISMS, aggiunta di un controllo aggiuntivo non Annex A) — richiedono nuova approvazione dell'Alta Direzione.

11. Storico delle revisioni

Rev.	Data	Descrizione	Redatto	Approvato
00	29/04/2026	Prima emissione dello Statement of Applicability ISO/IEC 27001:2022. Tutti i 93 controlli dell'Allegato A dichiarati Applicabili al perimetro ISMS di Toscana Diagnostica. Inclusi 8 controlli aggiuntivi non Annex A derivanti da NIS2, AI Act, IVDR, GDPR. Stato medio di implementazione 50% (12 Implementati, 64 Parzialmente implementati, 17 Pianificati). Documento emesso a chiusura della NC Maggiore P1 #21 del Report di Audit Documentale TD-SGI-RPT003_00.	RSGI + IT Manager	AD